

MediSecure Telehealth Inc.

Document ID: SEC-POL-025

Version: 1.0

Classification: Internal Use Only

Aligned Frameworks: ISO/IEC 27001:2022 (Controls A.8.13, A.8.16, A.8.20, A.5.24) | ITIL v4 (Incident & Major Incident Management)

1. PURPOSE

This policy defines the structural requirements, incoming email verification filters, and incident response procedures designed to protect MediSecure from phishing attacks, malware deployment, and unauthorized data exfiltration originating via corporate email.

2. SCOPE

This policy governs all corporate email accounts, email gateways, inbound/outbound mail traffic, and corporate endpoints utilized by MediSecure personnel.

3. POLICY STATEMENTS

3.1 Inbound Email Verification Standards (ISO 27001 A.8.20)

- **Domain Authentication:** The IT architecture team must enforce strict incoming validation for **SPF (Sender Policy Framework)**, **DKIM (DomainKeys Identified Mail)**, and **DMARC (Domain-based Message Authentication, Reporting, and Conformance)**.
- **Spoofing Prevention:** Any inbound email that fails DMARC alignment (impersonating a trusted partner or the `@medisecure.com` domain) must be quarantined automatically before hitting the user's inbox.

3.2 Automated Threat Analysis & Sandboxing (ISO 27001 A.8.13)

- **Secure Email Gateway (SEG):** All inbound traffic must pass through an enterprise Secure Email Gateway performing real-time analysis of the sender's reputation and IP history.
- **Link & Attachment Scanning:** The SEG must enforce dynamic URL sandboxing (rewriting links to check them for malicious scripts at the time of the click) and extract/detonate all incoming email attachments in a virtual sandbox environment to detect zero-day malware.

3.3 Centralized Logging & Auditing (ISO 27001 A.8.16)

- **Log Aggregation:** All email gateway traffic logs (senders, timestamps, message headers, attachment hashes) and corporate endpoint execution logs must be forwarded to the centralized SIEM system in real time.
 - **Data Retention:** Audit logs must be stored securely and remain accessible to security analysts for a minimum of 90 days to facilitate retroactive threat hunting and breach investigations.
-

4. INCIDENT MANAGEMENT WORKFLOW (ITIL Practice & ISO A.5.24)

When a potential phishing or data exfiltration event is detected, the SOC must execute the following structured **ITIL Incident Playbook**:

1. **Identification & Scoping:** The analyst must immediately identify the specific corporate email account targeted, the sender domain, the target device's host name, and its **MAC/IP addresses**.
 2. **Goal Assessment:** The analyst must quickly determine the attacker's primary objective by checking the payload properties (e.g., whether the link leads to a credential harvesting page, a data-stealing script, or malware designed for system exfiltration).
 3. **Containment Protocol:** If a malicious file has executed or credentials have been input:
 - Isolate the affected endpoint from the corporate network immediately using Endpoint Detection and Response (EDR) tools.
 - Revoke all active session tokens for the compromised user account.
 4. **Escalation Trigger:** If log analysis reveals that the phishing link has successfully spread horizontally to multiple internal corporate devices, the event must be escalated immediately to the **ITIL Major Incident Procedure**, bringing in the Network, Infrastructure, and Executive Risk teams.
-

5. ENFORCEMENT & TRAINING

All employees must participate in quarterly automated phishing simulation tests. Repeated failures to report suspicious emails, or intentional attempts to bypass email gateway filters, will require mandatory security re-education and potential review by HR.
